

한국에너지공단 상임감사

현 지 조 치

제 목 시스템 권한 관리 미흡

소 관 부 서 건물에너지실

조 치 부 서 건물에너지실

내 용

1. 업무개요

건물에너지실은 제로에너지건축물 인증 제도, 에너지절약 설계기준 제도, 건물부문 목표관리 제도, 공공기관 에너지 이용 합리화 제도 운영 및 에너지 절약계획서 검토 업무 등을 수행하고 있는데, 업무 담당자의 능률 향상과 신청자의 편의성을 높이기 위해 각 업무별로 전산시스템을 구축하여 운영하고 있다.

2. 관련 규정 및 판단 기준

「개인정보보호법」 제29조(안전조치의무) 및 동법 시행령 제30조(개인정보의 안전성 확보 조치)에 따르면, 개인정보처리자는 개인정보에 대한 접근 권한을 제한하기 위해 필요한 조치를 취하여야 한다.

따라서, 건물에너지실에서 관리하는 전산시스템에 입력된 신청자의 개인 및 기업 정보 등은 외부로 유출되지 않도록 보호되어야 하며, 권한이 없는 자가 개인정보에 접근하지 못하도록 철저히 관리하여야 한다.

3. 감사결과 확인된 문제점

건물에너지실은 제로에너지건축물 인증시스템, 건물에너지 서비스 통합

플랫폼 등 총 00개의 시스템을 구축·운영하고 있었으며, 이번 감사기간 동안 각 시스템별 관리자 권한 부여 현황을 점검한 결과, [표1]과 같이 0개의 시스템에서 전보, 휴직, 퇴사(인턴 포함) 등으로 업무를 종료한 자의 권한이 회수되지 않은 사례가 확인되었다. 이는 관리자 권한에 대한 관리가 적절하게 이루어지지 않고 있었음을 나타낸다.

[표1] 회수되지 않은 시스템 관리자 권한 명세

연번	시스템명	소 속	성 명	비 고
(기재생략)				

자료 : 건물에너지실 시스템별 사용자 관리 재구성

또한, 총 0개의 시스템은 관리자 계정을 공용으로 사용하고 있어, 해당 계정 정보를 알고 있는 누구나 관리자 권한으로 접속할 수 있는 것으로 확인되었다. ([표2] 참조) 이 중 0개 시스템은 외부 접속이 가능하여, 개인정보가 보안상 취약한 상태에 있었다.

[표2] 공용 관리자 계정을 사용하는 시스템

연번	시스템명	접속가능 여부	
		내부망	외부망

(기재생략)

이와 같이 관리자 권한을 부여받았거나 공용 관리자 계정을 사용하여 업무를 수행하였던 전임자 및 퇴직자 등이 해당 시스템에 등록된 개인이나 기업의 정보를 열람할 우려가 있었으므로, 관련 권한을 즉시 회수 조치하였다.